

Scope for SAP S/4 HANA Private Cloud Edition on subscription

General Scope

A. Security and Compliance Audits

1. Compliance/Certification Audits:

- a. CAS for “Audit Readiness” is proposed to be included to periodically review the SAP Application alignment with compliance requirement and best practices. The details are included in the CAS section.
- b. SOC1, SOC2 and ISO 27001 (along with SOA), 27017 and 27018 Certificates and audit reports shall be made available by SAP for all the infrastructure under SAP tenant.

2. Security Audit:

- a. **Infra Vulnerability Audit:** At least Annual VAPT audit of all NTPC-JPL Infrastructure under SAP shall be conducted by SAP through independent auditors and the audit reports/certificates shall be shared with NTPC-JPL.
- b. **Application Audit:** NTPC-JPL shall get the security audit of Internet facing portals done by Cert-In empanelled auditors however Mitigation of all reported vulnerabilities shall be in scope of the SAP (except for any custom developments done by NTPC-JPL). The audit shall be facilitated by NTPC-JPL Security Group.

B. Advanced Security and Compliance (Cloud Application Service):

Following additional services are required to ensure additional security and compliance checks on a periodic basis and shall also in ensuring adequate security posture on a continuous basis. Security Group shall be reviewing the reports and monitoring the closure along with NTPC-JPL SAP team.

1. Application and Interface Security:

- a) Application Security update Service (To be included in BoM) : SAP releases security notes every month on second Tuesday. The analysis of the SAP notes, prioritisation of the updates, implementation in DEV and transport to PRD by SAP shall be done after this service providing strong baseline security.
- b) Security for Interface Service (To be included in BoM): SAP will define a methodology on how to secure RFC function modules using Unified Connectivity and creating roles with restricted access for authorized users only.
SAP will identify used RFC modules and block not required RFC modules, restrict access of RFC modules via additional roles accordingly provided and whitelisted by UCON And shall also check the usage of encryption for RFC connections.

2. Application Security Monitoring Service (To be included in BoM) : SAP will continuously monitor Customer’s applications related to security statuses, so that the systems and SAP applications are operating in a secure mode. SAP will continuously monitor and report following Security KPIs.

- a) Secure configuration of SAP system:
 1. Application Server security checks

2. Security Note Implementation Status
3. Profile Parameter
4. Security Audit Log settings
5. Critical authorizations
6. Secure configuration of HANA system:
7. Security settings
8. Critical privileges

b) SAP will provide recommendations to resolve identified risks.

3. Security Governance and Compliance:

a) Security Risk Check Service (To be included in BoM) : SAP will analyze critical accesses and critical system settings on periodic basis. SAP will provide recommendations to remediate or mitigate the identified risks. SAP will scan the Customer's SAP productive systems for the following security risks:

1. Secure configuration of SAP system:

- i. Application Server security checks
- ii. Security Note Implementation Status
- iii. Profile Parameter
- iv. Security Audit Log settings.
- v. Critical authorizations
- vi. Review of customer authorization concept

2. Secure configuration of HANA system:

- i. Security settings
- ii. Critical privileges

3. SAP will create a scorecard of security risks KPIs.

4. SAP will initiate remediation for high risks findings.

b) Audit Readiness Service (To be included in BoM): SAP will review the critical accesses, policies and violations, designed to comply with external audit requirements. SAP will check if all security needs are reviewed before the audit and provide recommendations to remediate the identified issues. SAP identifies findings during the audit, reviews audit results and provides recommendations. SAP will conduct this service as follows:

a. SAP will conduct an Audit Readiness Check, which review for following KPIs:

- i. Availability of Customer's security processes, such as Security Guidelines, Development
- ii. Guidelines, Operational Manual, etc.
- iii. Security relevant processes, such as emergency user process
- iv. Security relevant settings of SAP system

b. SAP will initiate activities to remediate findings:

- i. Reviewing the IT controls as mitigation controls
- ii. Providing recommendations for configuring IT controls and mitigations of risks
- iii. Update security settings in SAP application server

c. SAP will resolve audit findings which were identified during the regular security audits.

C. Data Security and Privacy:

1. **Data Encryption:** All the data-at-rest (Storage) and data-in-motion used in SAP tenant shall be encrypted at multiple layers (storage, volume, OS level etc) by SAP through suitable encryption mechanisms. Hyperscaler KMS or Cloud HSM service shall be used for storing storage level encryption keys. SAP shall provide flexibility of BYOK in future, if NTPC-JPL opts for such service in future.
 2. **Reasonable protection of PII and sensitive information:** Reasonable security protections for securing any sensitive/confidential information such as AADHAR numbers, or any Personally identifiable information (PII) stored/processed in SAP RISE or BTP tenant shall be implemented by SAP and any enterprise responsibility on that part shall be clearly communicated to NTPC-JPL.
 3. **Compliance with DPDP Act:** Currently SAP does not provide any compliance services for DPDP Act 2023; however, the services may be explored in future whenever available.
- D. **Compliance with GOI and Indian Regulators guidelines:** Continued Compliance with relevant guidelines for CSPs and Service providers from GOI and Indian regulatory agencies (MEITY, Cert-IN, MHA etc.) shall be maintained by SAP (including for the sub-contractors) and any deviation shall be reported to NTPC-JPL on immediate basis. In case, there are any exclusions or NTPC-JPL has certain responsibilities towards the same, those shall be always intimated to NTPC on priority.
- E. **Response to Cyber Security Incidents/Weaknesses/Vulnerabilities:**
1. All the detected/reported/identified weaknesses/vulnerabilities and security incidents such as Data leakage, Security Breach, Encryption key theft, malware attack etc. affecting SAP or underlying CSP or other associated sub-contractors/service providers and which shall/may impact NTPC-JPL infra/applications/data hosted in SAP tenant shall be IMMEDIATELY reported to NTPC-JPL along with RCA to the extent possible, plan of action and suggested actions if any for NTPC-JPL team.
 2. In case, any security incidents/vulnerabilities/weaknesses are reported by any GOI/regulatory agency/vendor/auditor to NTPC-JPL regarding, the same shall be communicated to SAP and shall be actively investigated on priority by SAP, and remedial action shall be taken by SAP/CSP/sub-contractors on urgent basis. If any action is required to be taken by NTPC-JPL team, same shall be communicated to NTPC-JPL on priority. Post-incident an RCA and Action taken report may also be provided for learning.
 3. **Responsible Disclosure:** In case SAP itself (excluding NTPC-JPL tenant) is impacted by any cyber security incident, SAP shall make a responsible disclosure to NTPC-JPL as well to protect against Supply Chain Risk and plan additional mitigations/control at our end, if required.
- F. **Responsibility of Security of Infra. Hosted under SAP tenant or other SaaS, IaaS infra sub-contracted by SAP:** Security of Cloud hosted Infrastructure and applications is a joint responsibility. However, a clear demarcation of security responsibilities between SAP and NTPC-JPL shall be maintained as a living document (updated continuously on changes) by SAP so that there are no grey areas. This document shall be always available with NTPC-JPL team. Any security responsibilities for NTPC-JPL tenant regarding the sub-contracted services/Infrastructure including CSP shall be owned by SAP and managed accordingly with clear visibility to NTPC-JPL through the above documentation.